MOBILE DJ / PRODUCT BLUEPRINT

DOCUMENT 11 OF 19

Release, security and personal operation

A new touch-first performance instrument.
Professional audio, liquid glass and mechanical craft.



DESIGN HANDOFF BASELINE - PLANNING ONLY

29 October 2026 | Crystal Current selected; S26 Ultra test target

Independent of the previous Mixline preview. Targets are not measured results.

Version: 1.0 **Date:** 29 October 2026 **Status:** Design handoff baseline for local personal delivery; implementation and device validation remain unperformed **Product:** New mobile DJ application; no Mixline reuse **Platform direction:** Android first confirmed; iOS sequence unresolved **Owners:** Release lead, security lead, product owner and owner-operated service operator

1. Release promise

The user has selected Android first, serious mobile DJs as primary users, casual streaming DJs as secondary, and private practice/personal gatherings as the initial performance context. USB audio interfaces and DJ splitters are permitted. The intended feature scope includes all previously enumerated professional modules except lighting: four decks, prepared and live stems, sampler/sequencer, recording, automix, microphone, video/karaoke, broadcasting and plugin hosting. ParDay is the chosen name for the AI assistant, not a confirmed name for the whole app.

This is confirmed product ambition; technical support and source permissions still require evidence. Keep the modules in the requirements and delivery plan. If a device, license or partner prevents the intended full scope, show the gap and seek a product decision before representing a smaller release as complete. Private use does not justify reducing audio reliability, and “private gathering” must not be assumed to satisfy every provider's event or public-performance restrictions.

The product should make a defensible promise about the broader certified-device matrix, workloads, audio routes and media sources. “Professional” must correspond to measured sustained performance and recoverable workflows. Do not advertise universal latency, universal streaming compatibility or permission for commercial performance merely because a third-party catalog can technically play.

G0-G5 produce decisions, feasibility and working capabilities. G6 establishes a release candidate; G7 installs and validates the personal local release. G8 maintains it and can support separately chosen extensions. Cloud-specific G5 cases apply only when the later AWS extension is evaluated. Core beta at G3 is not a substitute for the complete intended professional product.

The owner has selected a personal tool, with openness to a later GitHub source release for others to home lab their own solutions. Public commercial distribution is not the current objective. The broader certified-device matrix, timing, exact licence/publication choice and actual source access remain unresolved. The latest owner decision is local first: build the phone-native app with no required server, including an on-device acquisition feasibility and implementation track. The on-device versus AWS comparison moves to a later optional expansion; no comparative winner is established. The owner has no local host selected and accepts AWS later with an approximate USD 35 monthly planning target excluding ParDay AI-provider charges. This target is not a hard ceiling, actual quote, selected resource configuration or deployment authorization. This document prepares personal installation and operation; optional publication, purchases and external outreach have not been executed.

2. Threat model and controls

The most important assets are uninterrupted valid audio, prepared libraries, recordings, provider credentials, private media and the release-signing chain. Untrusted boundaries include imported media/tags/artwork, archive backups, remote provider responses, external audio routes and hosted plugin code. Cloud sync, product purchase entitlements and billing callbacks are additional boundaries only if those features are selected later.

Threat	Required control	Evidence before release
Malformed media or artwork exploits a parser	Mature patched decoders; size/duration/artwork limits; defensive parsing; isolate work where practical; no parser work on callback.	Fuzz/regression corpus, crash triage and dependency review.

Threat	Required control	Evidence before release
Malicious archive overwrites files	Reject path traversal, symlinks outside permitted scope, duplicate IDs and decompression bombs. Stage and validate restore.	Adversarial backup/import cases.
Tokens or signing secrets leak	Platform secure storage for owner credentials; no shared app-owned paid secret in the APK; server secrets stay server-side if that service exists; protected signing and redacted logs.	Binary/repository/log secret scan and access review.
OAuth redirect or callback is hijacked	Use provider-approved authorization flow, PKCE where applicable, verified redirect handling and state validation.	Negative callback/replay tests per provider.
Remote response grants excessive rights	Capability decisions use validated contract/schema versions; unknown fails closed; record/export gate lives below UI.	Revoked/expired/malformed grant tests.
Sync destroys user preparation	Versioned records, explicit conflicts, tombstones, checkpoint/restore and migration fixtures.	Interrupted sync and conflicting cue/grid edits.
Telemetry exposes private music or speech	No uploaded audio, full file paths, tokens or detailed library metadata by default; opt-in diagnostics with reviewable contents.	Network inspection against actual consent/privacy text.
Unauthorized purchases or replayed entitlements, only if commercial billing is later added	Validate purchase state through supported platform flow; track idempotent transaction identity and revocation.	Test purchases, cancellation, restore, duplicate callback and offline behavior.
Plugin or model supply chain introduces code/risk	Pin exact versions/hashes, keep an SBOM and license record; prohibit downloaded executable code unless explicitly designed and policy-reviewed.	Provenance and vulnerability review; specialist module admission gate.
Route change leaks cue audio	Route identity and channel map validation; never reroute cue-only audio to main automatically.	Real-device unplug/replug and route-loss tests.
ParDay interprets an untrusted title, webpage or tool result as authority	Treat retrieved content as data; allowlist tools and parameter schemas; validate source permissions and current deck/route generations below the model.	Prompt-injection and stale-action cases cannot change playback, spend money or export restricted content.
AI gateway leaks provider data or private media	Field-level provenance, minimum prompt context, server-side secrets, model/vendor allowlist and explicit cloud consent.	Request inspection proves restricted fields, tokens and raw audio are absent from prohibited destinations.

Use least privilege. Request microphone access when the user enables microphone functionality, not on first launch. File selection should use scoped platform access. No contacts, location or broad storage access is needed merely to mix imported music. If a later feature requires additional access, add a clear purpose and update data handling documentation.

Security controls must not block the real-time thread. Queue logging, encryption, network validation and persistence elsewhere. A server outage or account login failure should not unexpectedly terminate an authorized offline local set. If product billing is added later, its app-entitlement behavior must define an offline allowance and session continuity rule while honoring separate provider expirations. Do not disguise a failed renewal as an audio-engine failure.

3. Privacy and data lifecycle

Maintain an inventory of data collected by the app and every SDK: purpose, local/remote location, retention, processor, consent, deletion and export behavior. Distinguish on-device music analysis from uploading music for cloud processing. Cloud stems or analytics require explicit product decisions and appropriate rights; they are not default infrastructure requirements.

ParDay's cloud use has its own data inventory: typed requests, optional speech, selected eligible metadata, conversation history, tool audit events, provider/model identity and retention. Core local mixing must remain functional when ParDay is off. Do not turn on ambient microphone capture to make the assistant feel present; offer an explicit push-to-talk path if voice is selected. Separate microphone permission for the mix from microphone permission/use for speech transmission. Changing between OpenAI, Anthropic or an on-device model changes processing and must be visible in settings and the data policy.

Spotify's ordinary terms prohibit AI ingestion of Spotify Content, and its policy also restricts voice-control assistants. [9,11] Review this independently of consent and cloud vendor training settings. Sending data to a “no training” endpoint is still model inference; that setting does not establish source permission. Document 07 defines provenance enforcement; Document 13 defines model routing, consent and action authority. Cached prompts, analytics and exported diagnostics require the same filter as interactive requests.

The default account-free local mode must retain a fully functional local core. Optional app-account deletion must remove associated cloud data and explain legitimately retained records. Disconnecting a music provider revokes its tokens and permitted caches without deleting unrelated user-owned media. Local preparation can remain only where allowed and chosen by the user. Export before deletion must be understandable, but deletion cannot be obstructed by unnecessary steps.

If public Google Play distribution is later selected, Google Play requires accurate Data safety information covering third-party SDK behavior and a privacy policy, including for apps that collect no user data. If the app supports in-app account creation, its account-deletion requirements include an in-app path and an external web resource. Verify exact applicability at submission. [1,2]

4. Personal installation, updates and recovery

The personal release needs an installable signed Android package, a stable package/application ID, recorded build provenance and a private signing-key backup controlled by the owner. Test fresh installation and an upgrade that preserves media access, crates, cues and settings. Keep signing material, API credentials and private configuration outside any publishable source tree. A debug or locally built prototype is not evidence of a reliable update path.

Document the installed app and optional server versions, supported S26 Ultra software/audio profile, settings and limits. Back up user preparation and configuration separately from regenerable caches and provider-controlled media; exercise restore before calling the release ready. Do not assume an older binary can read a newer database after a schema migration. Provide a tested rollback/recovery path, or clearly require restoring a compatible backup.

A later optional owner-operated service needs a paired device, bounded access, storage/retention settings, logs that omit credentials, and update/rollback instructions. AWS is the accepted expansion provider; final runtime and sizing follow the deferred comparison. None of this is a prerequisite for the first local installation. Document account ownership, region, access path, billing assumptions and resource cleanup before any deployment. Service outage must not prevent prepared local mixing. Local home-lab LAN/remote configurations remain optional portability references. Acquisition workers and ParDay cloud/gateway services have independent data and cost boundaries; see Documents 13, 16, 17 and 18.

4A. Conditional Google Play reference

Apply this checklist only if public Google Play distribution is selected later. These date-stamped research findings are not personal-release gates or a guarantee that future policy will remain unchanged. OS/native compatibility and correct installation still require testing for the selected personal package.

Gate	Deliverable / acceptance
Publisher identity	Confirm legal publisher, personal versus organization account, required verification, support contact and ownership of the package/signing process.
Target and packaging	As checked on 29 October 2026, official requirements specify Android 16/API 36 or higher for new mobile apps/updates after 31 August 2026. Recheck at release. Produce correctly signed release bundles, symbols and reproducible version metadata. [3]
Native compatibility	Verify supported ABIs and 16KB memory-page compatibility for the app and every bundled native SDK/library. Test actual packaged artifacts, not only compilation success. [4]
Foreground operation	Declare correct service types/permissions and Play Console information for user-initiated background media playback. Supply required demonstration and user-stop behavior. Microphone capture is a separate permission/lifecycle case. [5]
Data and permissions	Complete privacy policy, Data safety, permission declarations, account deletion where applicable and SDK inventory. Match real network behavior.
Content and rights	Complete content rating, audience and advertising declarations; submit truthful screenshots/descriptions; possess asset/model/codec/provider rights.
Payments	Choose a policy-compliant billing model for digital features. Google Play Billing is the default requirement unless an applicable current exception/program applies. Verify territory-specific obligations rather than assuming a universal exception. [6]
Testing access	For personal accounts created after 13 November 2023, current official guidance requires at least 12 continuously opted-in closed testers for 14 days before applying for production access. Account status determines applicability; this is not a rule triggered simply by calling an app commercial. [7]
Quality and review	Complete real-device audio certification, interruption/recovery, crash/ANR, accessibility and purchase tests. Supply reviewer access and clear instructions for optional account/provider paths.
Rollout	Use staged release, monitor supported-device failures and retain a tested rollback/forward-fix plan. Do not force an update during a live session.

If iOS is selected, create a separate Apple submission checklist from current official requirements at that milestone: App Store review, signing, privacy declarations, entitlements/background modes, purchase rules, permissions and device testing. Android approval and audio certification do not establish iOS readiness.

5. Rights and dependency review

Maintain six distinct records: software license, asset/model license, provider API/SDK agreement, end-user subscription grant, public-performance/venue context, and recording/broadcast/distribution permission. One does not substitute for another. Local file possession is not proof of permission to redistribute it. A venue's performance arrangements do not automatically change a streaming provider's contract.

For each DSP/codec/model dependency record the exact version, license, commercial terms, attribution, distribution obligations, platform/ABI support, maintenance status and exit option. A model repository's code license may not cover its weights or training-data claims. Do not infer a commercial SDK price from an old product page; request a current written quote after the required feature/workload is specified.

The user permits paid DSP licenses but prefers compatible open-source options. Evaluate open-source candidates first against quality, callback behavior, latency reporting, maintenance and distribution obligations; compare a paid candidate when those results justify it. “Open source” does not mean every license fits a closed-source commercial app, and “permitted to consider paid licenses” is not a purchase order. Record lifecycle cost and exit feasibility beside any proposed choice. Apply the same discipline to on-device AI runtimes, model weights, speech components, codec libraries and any hosted plugin standard.

Spotify's selected-DJ support explicitly excludes public venues/events/livestreams, while its ordinary Developer Policy prohibits mixing; Apple ordinary media terms also restrict commercial use. Existing named DJ partnerships do not grant this app equivalent rights. [8,9,10] Other providers require their own applicable contract review. Keep partner-blocked modules out of the public committed feature list until admitted.

The owner explicitly selected integrated link-to-file acquisition, including unofficial methods. Document 16 adds a real implementation track using replaceable extraction, direct-file or documented vendor adapters. Do not equate technical feasibility with service/content permission or store eligibility. Spotify terms restrict stream ripping and YouTube API policies restrict unauthorized download/separation; using another mechanism does not itself establish an exception to applicable service terms. [11,12] A CC/public-domain claim concerns content rights and does not by itself grant platform access permission.

The named Spotdown/Y2Mate pages demonstrate advertised consumer workflows, not verified app APIs or reusable commercial grants. The new evidence and deployment alternatives are in Document 16. Google Play specifically lists unauthorized downloading of copyrighted content and encouragement of infringement as violations; it does not prohibit every file downloader by category. [13] Public commercial distribution, a private APK and a self-hosted service have different operational implications, but none automatically supplies missing source rights. Record the four evidence dimensions independently and obtain a concrete release decision instead of deleting the requested capability or promising universal support.

Video/karaoke and broadcasting have their own rights review. A playable song does not automatically permit synchronized video, displayed lyrics, recording, remix distribution or an Internet broadcast. For user-managed local files, keep rights responsibility understandable without demanding ownership-proof uploads for routine importing. For provider-controlled sources, block only the operation that lacks permission and explain the available alternative.

6. Personal operating budget and optional commercial reference

No sales price or revenue model is required for the selected personal tool. The owner selected an approximate USD 35/month target for future AWS operation, excluding ParDay AI-provider charges, and explicitly deferred AWS until after the local version. No AWS infrastructure is needed for the first local version. Estimate development effort and recurring personal operating costs separately; local first is not a claim that optional external model calls, music services or all acquisition operations are free or offline. If commercial distribution is explicitly selected later, the historical alternatives are a one-time purchase, subscription, or paid core/modules; they are not current design requirements. Core performance remains independent of advertising or product billing.

Budget separately for native audio/DSP engineering, mobile interaction design, quality devices and audio routes, SDK/model licensing, commissioned music and assets, provider integration/certification, cloud/storage/egress if selected, privacy/dependency review, personal maintenance and ongoing OS compatibility. Store accounts, product billing and commercial support are conditional future costs. Four

decks, real-time stems, video and plugin hosting increase both development and certification effort; a cloud backend is not free simply because a service offers an initial free tier.

Add a ParDay budget with separate inputs for model requests/tokens, speech duration, retrieval/search, gateway hosting, logs, evaluations, support and optional local-model delivery. Set per-session and account spending limits, cancel stale requests, and avoid repeated full-library prompts. Consumer ChatGPT or Claude subscriptions must not be assumed to fund third-party API usage; confirm the actual selected service contract before quoting price. Do not choose a named model or estimate unit cost without a current benchmark and vendor pricing check at implementation.

Use a quote-driven model:

Development cost = role effort × agreed rates + licenses + assets + device/test equipment + external review.

Personal operating cost = model/API usage + applicable provider subscriptions + selected AWS compute/storage/network and other billed resources + maintenance.

No existing local host is selected or required. Use Document 18 and contracts/aws_cost_scenarios.json for the deferred AWS trial and approximately USD 35/month target. Keep that target distinct from an authorized trial spend, a verified bill and an enforced ceiling; do not treat estimates, free-tier eligibility or alert settings as a spending guarantee. Local hardware/electricity costs belong only to a later physical home-lab profile. If public distribution is later selected, add its store, payment and community/support costs separately.

Keep assumptions and confidence beside each input and separate one-time costs from recurring costs. Commercial break-even is outside the present personal-project acceptance criteria.

Historical commercial experiment, applicable only after a change of objective: recruit eight intended users. If four or more cannot supply 20 usable tracks for a normal set, or say missing catalog access prevents adoption, reject the claim that a local-only launch serves that audience's quick all-in-one need. Pursue a suitable partner or adjust the launch audience. This revises launch positioning without removing the offline engine or advanced final product.

7. Go/no-go record and operations

G6 requires the selected personal scope matrix, device/workload evidence, requirements traceability, no unresolved release-blocking defects, recoverable library/recording behavior, rights/asset ledger, security review, install/upgrade instructions and a tested backup/restore procedure. Store-submission materials and the deferred D-versus-AWS comparison are not gates for the first local personal release. Local acquisition, the complete selected professional scope and relevant local safety/quality evidence remain tracked; an unavailable module must be reported explicitly. Optional community publication adds Document 17's separate readiness checks. Unproven specialist modules remain visibly unavailable; they cannot be advertised as completed.

ParDay adds release evidence for task success, fabricated-track rejection, stale command rejection, prompt-injection resistance, provider-data egress, cancellation, budget enforcement and cloud outage behavior. At least one complete warm audio workload must run with active assistant requests and failures; only the device-certified combination may be advertised. AI demonstrations and concept images do not establish these results. Source integrations add Document 14's acquisition/provenance cases and Document 16's twenty DLA cases, including worker isolation, format honesty, Android stop behavior and the actual media-source distinction. No downloaded media, paid account, partner approval or new API key was acquired during this planning revision.

Assign maintenance responsibility for crash/audio regression, source or owner-operated service outage, corrupted library, credential rotation and data deletion. Commercial purchase/support workflows apply only if later selected. Incident reports record affected versions/devices, user impact, mitigation and verification.

Signed remote configuration may disable a faulty optional integration safely; it must not introduce arbitrary code or unexpectedly alter the live mix. Rollouts and migrations should occur outside active performance.

Track voluntary product metrics that answer actual questions: time to first successful mix, completion of cue/transition workflows, sustained-session success, recovery rate, repeat use and support burden. Do not collect track content merely because analytics makes it convenient. Use local, optional diagnostics for the owner's personal acceptance and maintenance. Revisit a commercial plan only if the owner changes that objective; optional GitHub interest does not itself make the app a commercial service.

Sources

1. Google Play Data safety guidance.
2. Google Play User Data policy.
3. Android target API requirements.
4. Android 16KB page-size compatibility.
5. Foreground service requirements and Android service types.
6. Google Play Payments policy.
7. Testing requirements for new personal accounts.
8. Spotify DJ support.
9. Spotify Developer Policy.
10. Apple Media Services terms, applicable territory to be confirmed.
11. Spotify Developer Terms.
12. YouTube API Developer Policies.
13. Google Play intellectual property policy.